# 05 Owasp

Lois-Kleinner Alpasan · Anticloud FZ LLE · PAX L5 Narrow L2 General 27B

## OWASP Top 10 Assessment — OPENBALLISTIX

| **Company:** Anticloud FZ LLE | **Standard:** OWASP Top 10 2021 |
|---|---|

| # | Category | Mitigation | Status |
|---|---|---|---|
| A01 | Broken Access Control | Zero-trust mTLS: every call authenticated | PASS |
| A02 | Cryptographic Failures | AES-256-GCM at rest, TLS 1.3 in transit | PASS |
| A03 | Injection | Parameterized queries, no shell exec from user input | PASS |
| A04 | Insecure Design | Threat model documented, offline-first by design | PASS |
| A05 | Security Misconfiguration | Single binary: no misconfigurable cloud console | PASS |
| A06 | Vulnerable Components | SBOM embedded, deterministic builds, pinned deps | PASS |
| A07 | Auth & Session Failures | mTLS short-lived certs, no session tokens | PASS |
| A08 | Software & Data Integrity | AIOSS + Provenance chain on every mutation | PASS |
| A09 | Security Logging | Local observability: all events logged locally | PASS |
| A10 | SSRF | No outbound HTTP in offline mode, allowlist only | PASS |

## 1. Additional: LLM Top 10 (OWASP LLM01-LLM10 2025)

| # | Category | Mitigation | Status |
|---|---|---|---|
| LLM01 | Prompt Injection | Input sanitization + output validation | PASS |
| LLM02 | Insecure Output Handling | Structured output validator, schema enforcement | PASS |
| LLM03 | Training Data Poisoning | Model weights verified via hash, not retrained online | PASS |
| LLM04 | Model Denial of Service | Token budget enforced, request queuing | PASS |
| LLM05 | Supply Chain Vulnerabilities | SBOM, deterministic build, pinned GGUF hash | PASS |
| LLM06 | Sensitive Info Disclosure | Sovereign Memory encrypted, no plaintext logs of prompts | PASS |
| LLM07 | Insecure Plugin Design | No plugins; all tools compiled into single binary | PASS |
| LLM08 | Excessive Agency | PAX operates in read-only mode by default | PASS |
| LLM09 | Overreliance | Human-in-the-loop required for all write operations | PASS |
| LLM10 | Model Theft | Model runs locally; GGUF never transmitted externally | PASS |